

By entering this website, you consent to the use of technologies, such as cookies and analytics, to customise content, advertising and provide social media features. This will be used to analyse traffic to the website, allowing us to understand visitor preferences and improving our services.

[Learn more](#)

I ACCEPT

Cyber attack on ICRC: What we know



ARTICLE | 16 FEBRUARY 2022 | SWITZERLAND



Update: 24 June 2022.

In January, we determined that servers hosting personal data belonging to more than 515,000 people worldwide were hacked in a sophisticated cyber attack.

We feel it is our responsibility as a humanitarian organization accountable to our partners and the people we serve to share what information we can about this hack.

What should I do if I think my data might have been accessed in the cyber attack?

If you haven't heard from us and are concerned, we encourage you to reach out to your local Red Cross or Red Crescent society or the ICRC office in your country. Here is a [list of contact details](#). We also developed a [question and answers article for people who have been affected](#) with more information. We know you entrusted us with personal information and details about often traumatic events in your lives. This is not a responsibility we take lightly. We will work hard to maintain your trust so we can continue to serve you.

Are your systems back online?

Yes. The systems are now back online, which is critically important in allowing Red Cross and Red Crescent teams around the world to help reconnect separated family members. They have been relaunched with security enhancements, including new two-factor authentication process and advanced threat detection solution. The applications and systems went back online only after successful, externally conducted penetration tests. We continue to monitor our systems closely and make relevant security enhancements.

How are you informing people who were affected?

We have been working with National Red Cross and Red Crescent Societies and our ICRC delegations on the ground to inform individuals and families whose data was breached. This process is complex and ongoing, with each case being managed based on individual risk assessments. Some of this is being done through phone calls, hotlines, public announcements, letters and in some cases it requires teams to travel to remote communities to inform people in-person. We are making every effort to contact people who can be difficult to reach, such as migrants. Most of the people we have informed want us to continue to work to find their relatives. We know the emotional toll that a missing family member takes on a person. We will continue do everything we can to help them find the answers they deserve.

What made this attack highly sophisticated and targeted?

The hackers made use of considerable resources to access our systems and used tactics that most detection tools would not have picked up. The following information demonstrates the sophisticated and targeted nature of the attack:

- The attackers used a very specific set of advanced hacking tools designed for offensive security. These tools are primarily used by advanced persistent

threat* groups, are not available publicly and therefore out of reach to other actors.

- The attackers used sophisticated obfuscation techniques to hide and protect their malicious programs. This requires a high level of skills only available to a limited number of actors.
- We determined the attack to be targeted because the attackers created a piece of code designed purely for execution on the targeted ICRC servers. The tools used by the attacker explicitly referred to a unique identifier on the targeted servers (its MAC address).
- The anti-malware tools we had installed on the targeted servers were active and did detect and block some of the files used by the attackers. But most of the malicious files deployed were specifically crafted to bypass our anti-malware solutions, and it was only when we installed advanced endpoint detection and response (EDR) agents as part of our planned enhancement programme that this intrusion was detected.

When did we find out about this attack?

A specialist cyber security company hired by ICRC to support us in protecting our systems detected an anomaly on ICRC servers that contained information relating to the International Red Cross and Red Crescent Movement's Restoring Family Links services. We then did a deep data dive and determined on 18 January that hackers had been inside these systems and had access to the data on them.

How long were the hackers inside our systems?

In this case, we detected an anomaly in our system within 70 days of the breach occurring and we immediately initiated a deep dive. On that basis, we could determine on 18 January that our servers had been compromised. Our analysis shows that the breach occurred on 9 November 2021.

A breach this large and complex typically takes time to detect. For example, we understand that the average time to identify a data breach is 212 days**.

How did the hackers get into our systems?

The hackers were able to enter our network and access our systems by exploiting an unpatched critical vulnerability*** in an authentication module (CVE-2021-40539). This vulnerability allows malicious cyber actors to place web shells and conduct post-exploitation activities such as compromising administrator credentials, conducting lateral movement, and exfiltrating registry hives and Active Directory files. Once inside our network, the hackers were able to deploy offensive security tools which allowed them to disguise themselves as legitimate users or administrators. This in turn allowed them to access the data, despite this data being encrypted.

What went wrong with our defences?

The patching process is an extensive activity for any large enterprise. Annually, we implement tens of thousands of patches across all our systems. The timely application of critical patches is essential to our cyber security, but unfortunately, we did not apply this patch in time before the attack took place.

We have a multi-level cyber defence system at the ICRC that includes endpoint monitoring, scanning software and other tools. In this instance our analysis after the attack revealed that our vulnerability management processes and tools did not stop this breach. We have made immediate changes in both areas. Furthermore, we are speeding up the activities already planned as part of our latest cyber security enhancement programme launched in February 2021 in response to constantly evolving threats.

Who do we think is behind this attack?

We cannot ascertain who is behind this attack or why it was carried out, and we will not speculate about this. We have not had any contact with the hackers and no ransom ask has been made. In line with our standing practice to engage with any actor who can facilitate or impede our humanitarian work, we are willing to communicate directly and confidentially with whoever may be responsible for this operation to impress upon them the need to respect our humanitarian action. We also reiterate our call to the hackers not to share, sell, leak or otherwise use this data.

What information was accessed?

The breach included personal data such as names, locations, and contact information of more than 515,000 people from across the world. The people affected include missing people and their families, detainees and other people receiving services from the International Red Cross and Red Crescent Movement as a result of armed conflict,

natural disasters or migration. We do not believe it is in the best interest of the people whose data this is to share further details about who they are, where they are or where they came from.

Were data sets copied and exported?

We must presume so. We know that the hackers were inside our systems and therefore had the capacity to copy and export it. To our knowledge the information has not been published or traded. No data was deleted in the breach. This is important because it has allowed us to relaunch our systems and get back to work reconnecting loved ones.

How confident are we that the hackers are no longer in our systems?

We took the compromised servers offline as soon as we determined that they had been hacked. This incident did not affect other servers because we segment our systems and we are continually monitoring the overall environment for any signs of malicious activity with advanced tools.

Why are we not giving out further technical information about the hack or our systems?

We take cyber security very seriously and have been investing substantially in this over many years. These investments must continue in the face of an ever-evolving threat landscape. To ensure the security of our applications and in line with industry best practice, we will not disclose technical architecture or security details.

What other steps are you taking to prevent this from happening again?

The data breach highlights a growing trend in cyber operations targeted at humanitarian organizations. Data breaches risk causing severe consequences for the people those organisations serve – and those who are already among the most vulnerable. The **ICRC is now working with its Movement partners** to send a call to states and other actors about the need to protect humanitarian organizations online as they do offline.

**An advanced persistent threat (APT) is a stealthy threat actor, typically a nation state or state-sponsored group, which gains unauthorized access to a computer network and remains undetected for an extended period. In recent times, the term may also refer to non-state-sponsored groups conducting large-scale targeted intrusions for specific goals (Reference: https://en.wikipedia.org/wiki/Advanced_persistent_threat)*

***From IBM's "Cost of a Data Breach Report 2021": "In 2021 it took an average of 212 days to identify a breach and an average 75 days to contain a breach, for a total lifecycle of 287 days." (Reference: <https://www.ibm.com/security/data-breach>)*

****Reference: <https://nvd.nist.gov/vuln/detail/cve-2021-40539>*

Related



Sophisticated cyber-attack targets Red Cross Red Crescent data on 500,000 people

Cyber security incident: How could it affect me?

Topics

The ICRC and Data Protection